AI 原生開發：
做得快，也管得住

從框架到實務：可重複的流程、內建治理、關鍵決定由人做

PwC FSC1 | 給保險業的提案 | 2026 年 10 月

一頁看懂：做得快也管得住，從一個用例開始

先做 4–6 週診斷與 6–8 週單一用例試點；達標後，範本、規則與關卡沿用到下一個系統。

1 為什麼是現在

委外新辦法與 AI 自律規範已上路， AI 產出的最終責任在保險公司；開發流程要拿得出「誰要求、 AI 做了什麼、誰核准」的紀錄。

詳見第 3、 8 頁

2 為什麼只買工具不夠

國際研究： AI 讓交付變快，但也更不穩； PwC 調查也顯示，多數 CEO 還沒看到 AI 的財務效益。差別在流程與治理。

詳見第 4 頁

3 為什麼找我們

FSC1 自己已經用這套流程開發；懂保險業務與法規的 BA 和實作的 IT 同一組人，從貴公司的一個真實需求開始。

詳見第 7 頁

請貴公司決定

安排一場現場示範，指定 IT 與業務窗口，選出 1–2 個候選用例，啟動準備度診斷。

如果先不做

AI 工具照樣在開發團隊擴散，但流程與紀錄沒跟上；等到金檢或內稽時再補紀錄，成本更高、風險更大。

保險公司現在就要把 AI 治理設計進開發流程

保險業過半已在用 AI ，生成式 AI 快速擴散；但 AI 寫的程式近半有資安漏洞，而責任在保險公司。

保險業已在用 AI

53%

2024 年是 43% ；壽險公司更高達 65% 。

來源：金管會 2026-10 調查（工商時報）

生成式 AI 擴散

76%

有用 AI 的金融業者中，已導入生成式 AI 的比例；一年前是 48% 。

來源：金管會 2026-10 調查（聯合報）

AI 寫的程式

45%

含有資安漏洞。測了 100 多個 AI 模型、80 個寫程式任務。

來源：Veracode，2025-07

責任在誰：委外新辦法（2025 年底施行）和 AI 自律規範都寫明， AI 產出的最終責任在保險公司。紀錄要設計進流程，不能事後補。

AI 已普及，但交付沒有跟著變好： AI 放大原有的流程與治理

AI 已經普及，但多數企業還沒看到財務效益；差別在流程與治理，不在工具。

開發者	JPMorgan	Citi	保險業高階主管
84% 正在使用或計畫使用 AI 工具	**10–20%** 工程師生產力提升（公司自述）	**3 萬名** 開發者導入 AI 寫程式助手	**57%** 把生成式 AI 列為 2026 年首要科技投資（PwC 調查）

交付：快了，但更不穩

↑ 交付速度變快

↓ 交付穩定度下降

舊系統的效益比較小

35–40% 新寫的簡單功能

≤ 10% 複雜的既有系統

CEO 怎麼說（PwC 調查）

56% 還沒看到 AI 帶來明顯的財務效益

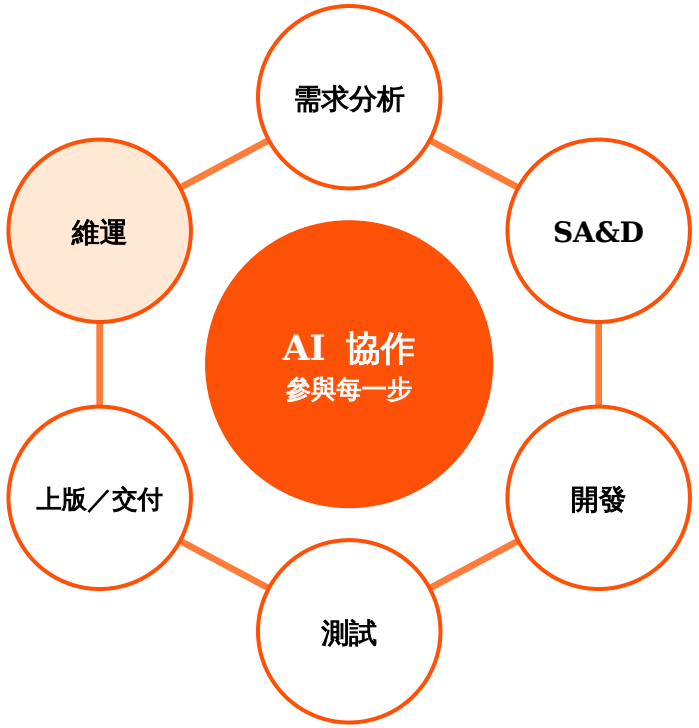
所以：效益取決於流程與治理，不取決於買了哪個工具。導入 AI 時，需求、審查、上線與控制方式要一起改，這正是我們協助的部分。

來源： Stack Overflow 2025；JPMorgan（Yahoo Finance）；Citi（Deloitte Insights）；PwC 保險高階主管調查；PwC 第 29 屆全球 CEO 調查

交付速度與穩定度：Google DORA 2025；既有系統效益：Stanford 軟體工程生產力研究（經 DORA 2026 引用）

我們的解法：把開發流程串成循環，用三個機制守住

AI 參與每一步；接受需求、核准合併、授權上線等五個關鍵決定，由貴公司指定的人做。



機制	怎麼運作	解決的問題
交接靠檔案	需求說明 → 規格 → 實作計畫 → 測試結果 → 核准紀錄，下一步直接接手	需求反覆、交接失真
規則自動執行	資安、個資、委外規範寫成 AI 自動套用的規則；必守的事由自動關卡擋下	合規與品質靠個人
關卡有人簽	接受需求、確認規格、核准計畫、核准合併、授權上線，五個決定由指定的人做	怕失控、稽核查不到

原則： AI 可以一路做到正式環境、把上線準備好，但不能自己按下上線。本方法不綁特定 AI 工具，依貴公司政策與合約選定。

流程整合自 FSC1 〈AI 協作開發流程與產出範本〉 v3 。國際研究也建議用不可略過的檢查點、提交前自動檢查、小批次與版本控制，承接 AI 帶來的審查負擔。

AI 分工：重複、判斷少的先交給 AI ；關鍵決定永遠由人做

依任務「多常發生 × 需要判斷」分四類；第一個試點用例，優先挑左上角工作多的需求。

常發生	常發生 × 判斷少 **AI 先做，人確認** ★ 從這裡開始 欄位清單、 Test Case 、 Test Data 、 Unit Test 、註解與文件、 Release Note	常發生 × 判斷多 **AI 起草，人逐項審查** 程式碼、 API 規格、 ERD 、 Code Review 風險檢查、測試失敗原因分析
少發生	少發生 × 判斷少 **做成範本，重複使用** Deploy Guide 、 User Guide 、 Migration Script 、部署腳本	少發生 × 判斷多 **人決定， AI 只提供資料** 接受需求、架構選型、核准合併、授權上線、事件處置
	需要判斷：少 ——————————→ 多	

第一階段：從左上角開始

① 先挑左上角
第一個試點，挑這類工作多的需求： AI 先做、人確認，最快看到效果。

② 右下角永遠由人決定
接受需求、核准合併、授權上線，就是五個人工關卡（第 5 頁）。

③ 依實際專案調整
分類在診斷時，依貴公司的專案與規範確認（第 9 頁）。

整理自 FSC1 開發流程實務；方法參考 MIT Sloan Management Review ， 2024 。分類為初步判斷。

現場示範：再保險系統主檔模組，從業務規則到上線畫面

以 FSC1 IT 團隊的實作為例：規則、規格、任務與測試一路相連；下方錄影是系統自動跑的畫面測試。

待確認

1 需求說明

SA_SPEC.md

業務規則（BR-0101-03）

規則代碼	規則名稱
BR-FI-01	代碼唯一性約束
BR-FI-02	引用後鎖定唯讀
BR-FI-03	引用防刪與軟作廢
BR-FI-04	SWIFT/BIC 格式檢核
BR-FI-05	作廢資料隔離與追溯
BR-FI-06	制裁連動與主管覆核
BR-FI-07	順序自動計算

7 條業務規則，含制裁主管覆核

2 規格與規範

specs/

```
FinancialInstitution_DBA_SPEC.md
FinancialInstitution_QA_SPEC.md
SA_SPEC.md
FinancialInstitution_SD_SPEC.md
FinancialInstitution_UI_SPEC.md
FinancialInstitution_USE_CASE_SPEC.md
```

```
last_reviewed: "2026-10-15"
review_cadence: "QUARTERLY"
next_review_due: "2027-01-15"
```

6 份規格，各有審閱週期

3 實作計畫

TASK-000013-001_Backend.md

- 場景 3 (代碼重複衝突 - TC-FI-03)：
  - Given: 系統已存在代碼 `"BOT001"`。
  - When: 發送 `POST /api/v1/system/financial-institutions` 傳入相同的 `code = "BOT001"`。
  - Then: 回傳 `HTTP 409 Conflict`，錯誤代碼為 `ERR_DUPLICATE_BANK_CODE`。

可修改檔案（最多 5 個）

1. `V6__create_system_financial_institutions.sql`
2. `FinancialInstitution.java`
3. `FinancialInstitutionRepository.java`
4. `FinancialInstitutionService.java`
5. `FinancialInstitutionController.java`

列明驗收場景，最多改 5 個檔案

4 程式與測試

QA_SPEC.md

案例代碼	測試場景
TC-FI-03	代碼重複衝突檢驗
TC-FI-04	SWIFT/BIC 格式檢核
TC-FI-05	受制裁國家建檔阻擋
TC-FI-06	受制裁國家建檔主管授權放行
TC-FI-07	被引用機構禁止物理刪除

1. 後端 `FinancialInstitutionServiceTest` 覆蓋率 > 90%，執行 `mvn test` 0 Failure 0 Error。
2. 前端 `npx tsc --noEmit` 型別檢查 0 Error。
3. 全系統執行 `python3 scripts/audit-specs.py` 5/5 閘門 100% 通過。

10 個測試案例；閘門要求覆蓋率 > 90%

5 追溯與紀錄

TASK-000013-001 · SD_SPEC

規格追溯依據

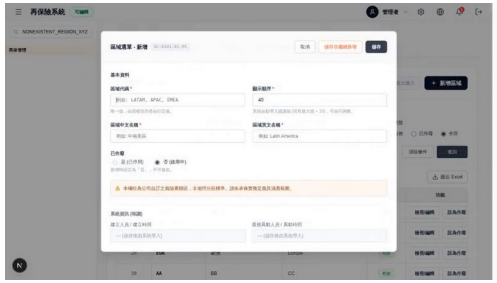
- 系統分析規格：(§2 BR-FI-01, BR-FI-04, BR-FI-07)
- 使用案例規格：(UC-FI-01, UC-FI-02, UC-FI-05)
- 資料庫規格：(system_financial_institutions)
- 系統詳細設計：(§1, §2)
- 測試案例：(TC-FI-01 ~ TC-FI-04, TC-FI-09)

```
Svc->>Audit: recordAudit(CREATE, "經主管授權建立受制裁國家機構")
```

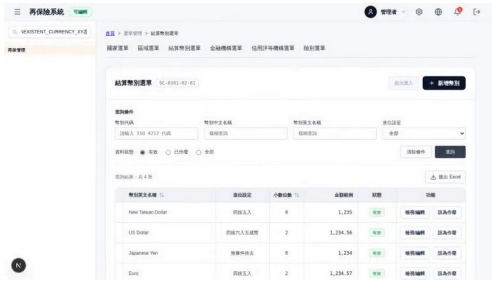
任務回溯規則代碼，寫入審計



▶ 國家選單：查詢、新增、欄位檢核



▶ 區域選單：新增與提醒



▶ 結算幣別選單：查詢結果

上方為 TASK-000013 「金融機構主檔」任務包原文節錄；下方為同一系統自動執行畫面測試的錄影（點擊播放，測試資料）。

給法遵與風控：每一個 AI 產出，都查得到誰要求、誰核准

金檢與內稽一定會問這五題，每一題都有做法、也留得下紀錄。

AI 工具有納管嗎？	個資會進到 AI 嗎？	上線是誰核准的？	出事能退回嗎？	事後查得到嗎？
診斷時就判斷是否屬委外，並登錄 AI 清冊。	資料分級，機密檔 AI 讀不到；試點用假資料。	指定的人核准； AI 不能核准自己寫的程式。	退版先演練； AI 建議退版，人決定。	需求、規格、計畫、測試結果都存版本。
留下： AI 清冊	**留下：**設定與存取紀錄	**留下：**核准紀錄	**留下：**演練紀錄	**留下：**完整文件軌跡

一句話： AI 的使用，從「難以稽核的個人行為」變成「有紀錄的流程」。法規檢查清單是草稿，診斷時與貴公司法遵逐條確認。

你買到什麼：先診斷，再做一個用例的試點

成功標準在試點前雙方講好，達標才擴大；固定範圍、固定價格，金額另行報價。

建議 | 示意

準備度診斷 約 4–6 週

- 盤點現況與卡點、法規檢查
- 挑出第一個用例
- 雙方訂好成功標準

交付：瓶頸地圖、法規檢查結果、用例建議、導入藍圖

一個用例的試點 約 6–8 週

- 用一個真實需求走完循環
- 建立範本、規範規則與關卡
- 同步教會各角色

交付：完成的試點、範本與規則、教材、成效報告

成功標準（試點前講好）

- 需求定稿時間
- 第一次審查等待時間
- 返工次數
- 核准紀錄完整（流程內建的必要條件）
- 合格線：以診斷期量到的基準，試點前約定

達標：擴大到下一個用例
未達標：檢討後再試或停止

貴公司需配合： IT 與業務窗口、一個真實需求與團隊、測試環境、 AI 工具的合約或內部核准。

我們的團隊：懂保險業務與法規的 BA 主導需求與法規檢查， IT 主導實作與示範；同一組人從診斷做到試點。

期程依範圍確認。擴大階段、工具包授權與駐點支援可依需求討論。

如何開始：先看現場示範，再挑一個用例

三個步驟就能開始；請貴公司先指定窗口，並給我們一份想做的需求清單。

示意

0 準備度診斷	1 用例試點	2 相鄰用例	3 全公司
約 4–6 週	約 6–8 週	依範圍	持續
進下一步：選定用例與成功標準	進下一步：指標達到合格線	進下一步：管理層核准擴大	進下一步：—

1

現場示範

拿貴公司的一個真實需求，當場跑一次：從寫需求到上線前的核准。

2

一起挑題目

開一次會，挑出 1–2 個最適合先做的需求，順便確認資料、系統和法規上有哪些限制。

3

開始診斷

定好範圍和雙方窗口，開始盤點現在的開發流程和法規要求。

請貴公司提供

- IT 主管與業務單位窗口
- 現有開發流程與工具（Jira 、 CI 、變更管理）
- 候選需求清單
- 資安、個資與法遵規範

一句話： AI 幫你把每一步做得更快，每一步都留下紀錄；要不要做、能不能上線，永遠由你的人決定。